FedRAMP Readiness Checklist

A Comprehensive Guide to Federal Risk and Authorization Management Program Compliance

Published by NexDyne Technology
Intelligence, Delivered

Executive Summary

The Federal Risk and Authorization Management Program (FedRAMP) provides a standardized approach to security assessment, authorization, and continuous monitoring for cloud products and services used by federal agencies. This comprehensive checklist guides organizations through the critical steps required to achieve FedRAMP authorization, from initial assessment to ongoing compliance.

Key Benefits of FedRAMP Authorization:

- Access to federal government contracts worth billions annually
- Streamlined security assessment process across multiple agencies
- Enhanced security posture and risk management
- Competitive advantage in the federal marketplace
- Reduced time and cost for security authorizations

Understanding FedRAMP Impact Levels

Before beginning your FedRAMP journey, determine the appropriate impact level for your cloud service:

Low Impact (LI-SaaS)

- **Data Classification:** Public information only
- **Controls Required:** 125 baseline security controls
- **Use Cases:** Collaboration tools, public websites, general productivity applications
- **Authorization Time:** 3-6 months
- **Annual Cost:** $150,000-$300,000

Moderate Impact

- **Data Classification:** Controlled Unclassified Information (CUI)
- **Controls Required:** 325 baseline security controls
- **Use Cases:** Email systems, financial management, HR systems, case management
- **Authorization Time:** 6-12 months
- **Annual Cost:** $500,000-$1.5 million

High Impact

- **Data Classification:** National security systems, law enforcement data
- **Controls Required:** 421 baseline security controls
- **Use Cases:** Intelligence systems, classified information, critical infrastructure
- **Authorization Time:** 12-18 months
- **Annual Cost:** $2 million-$5 million+

Phase 1: Pre-Authorization Planning (Months 1-2)

☐ Conduct Initial Assessment

- [ ] Identify target FedRAMP impact level (Low, Moderate, or High)
- [ ] Determine authorization path (Agency or JAB P-ATO)

- [ ] Assess current security posture against FedRAMP requirements
- [ ] Identify gaps in existing security controls
- [ ] Estimate budget and timeline requirements

☐ Build Your FedRAMP Team

- [ ] Assign FedRAMP Program Manager
- [ ] Designate System Owner and Authorizing Official
- [ ] Identify Information System Security Officer (ISSO)
- [ ] Engage Third-Party Assessment Organization (3PAO)
- [ ] Establish relationships with potential agency sponsors

☐ Define System Boundary

- [ ] Document all system components and services
- [ ] Identify data flows and integration points
- [ ] Map network architecture and infrastructure
- [ ] Define authorization boundary clearly
- [ ] Document external dependencies and connections

☐ Develop Project Plan

- [ ] Create detailed project timeline with milestones
- [ ] Allocate budget for assessment, remediation, and ongoing monitoring
- [ ] Establish governance structure and decision-making authority
- [ ] Define communication protocols with stakeholders
- [ ] Set up project tracking and reporting mechanisms

Phase 2: Documentation Development (Months 3-5)

☐ System Security Plan (SSP)

- ☐ Complete SSP template from FedRAMP website
- ☐ Document all 325 security controls (Moderate) or 125 (Low)
- ☐ Provide implementation statements for each control
- ☐ Include system architecture diagrams
- ☐ Document data flow diagrams
- ☐ Describe incident response procedures
- ☐ Detail configuration management processes
- ☐ Map controls to responsible parties

Critical SSP Sections:

- System identification and characteristics
- Security control implementation details
- Interconnection security agreements
- Continuous monitoring strategy
- Plan of Action and Milestones (POA&M)

☐ Security Assessment Plan (SAP)

- ☐ Work with 3PAO to develop comprehensive SAP
- ☐ Define testing methodology and scope
- ☐ Identify test cases for each security control
- ☐ Schedule assessment activities
- ☐ Coordinate access requirements with 3PAO
- ☐ Establish testing environment

☐ Supporting Documentation

- ☐ Policies and procedures library

- [ ] Configuration management documentation
- [ ] Incident response plan
- [ ] Contingency plan and disaster recovery procedures
- [ ] Privacy impact assessment
- [ ] Rules of behavior for system users
- [ ] Information security training materials
- [ ] Inventory of system components and assets

Phase 3: Technical Implementation (Months 3-6)

☐ Access Control (AC)

- [ ] Implement multi-factor authentication (MFA) for all users
- [ ] Configure role-based access control (RBAC)
- [ ] Establish least privilege access principles
- [ ] Document account management procedures
- [ ] Implement session timeout controls
- [ ] Configure failed login attempt lockouts
- [ ] Establish remote access security controls

☐ Audit and Accountability (AU)

- [ ] Enable comprehensive logging across all system components
- [ ] Implement centralized log management solution
- [ ] Configure log retention for minimum 90 days
- [ ] Establish audit review procedures
- [ ] Implement time synchronization (NTP)
- [ ] Protect audit logs from unauthorized access
- [ ] Configure alerts for security-relevant events

☐ Security Assessment and Authorization (CA)

- ☐ Conduct vulnerability scanning (monthly minimum)
- ☐ Perform penetration testing
- ☐ Complete security control assessments
- ☐ Develop Plan of Action and Milestones (POA&M)
- ☐ Establish continuous monitoring program
- ☐ Document interconnection security agreements

☐ Configuration Management (CM)

- ☐ Establish baseline configurations for all components
- ☐ Implement configuration change control process
- ☐ Deploy automated configuration monitoring
- ☐ Document security impact analysis procedures
- ☐ Maintain configuration management database
- ☐ Implement least functionality principle

☐ Contingency Planning (CP)

- ☐ Develop comprehensive contingency plan
- ☐ Establish backup procedures (daily incremental, weekly full)
- ☐ Document disaster recovery procedures
- ☐ Define Recovery Time Objective (RTO) and Recovery Point Objective (RPO)
- ☐ Conduct contingency plan testing annually
- ☐ Establish alternate processing site

☐ Identification and Authentication (IA)

- ☐ Implement unique user identification
- ☐ Deploy multi-factor authentication (MFA)
- ☐ Establish password complexity requirements (minimum 12 characters)

- [ ] Configure password expiration (maximum 60 days)
- [ ] Implement account lockout after failed attempts
- [ ] Establish authenticator management procedures

☐ Incident Response (IR)

- [ ] Develop incident response plan
- [ ] Establish incident response team
- [ ] Define incident categories and severity levels
- [ ] Implement incident tracking system
- [ ] Establish notification procedures (agency within 1 hour)
- [ ] Document incident handling procedures
- [ ] Conduct incident response training

☐ System and Communications Protection (SC)

- [ ] Implement boundary protection (firewalls, IDS/IPS)
- [ ] Configure encryption for data in transit (TLS 1.2+)
- [ ] Implement encryption for data at rest (AES-256)
- [ ] Establish network segmentation
- [ ] Deploy denial of service protection
- [ ] Implement secure communications protocols
- [ ] Configure cryptographic key management

☐ System and Information Integrity (SI)

- [ ] Deploy malware protection on all endpoints
- [ ] Implement intrusion detection/prevention systems
- [ ] Configure automated vulnerability scanning
- [ ] Establish patch management process (high-risk within 30 days)
- [ ] Implement security alerts and advisories monitoring
- [ ] Deploy file integrity monitoring

- [ ] Establish software integrity verification

Phase 4: Third-Party Assessment (Months 6-8)

☐ 3PAO Engagement

- [ ] Select FedRAMP-accredited 3PAO from marketplace
- [ ] Negotiate statement of work and pricing
- [ ] Provide 3PAO access to system and documentation
- [ ] Coordinate assessment schedule
- [ ] Assign points of contact for assessment activities

☐ Security Assessment

- [ ] Complete interview-based control testing
- [ ] Undergo technical security testing
- [ ] Participate in penetration testing activities
- [ ] Provide evidence for control implementation
- [ ] Address 3PAO questions and information requests
- [ ] Review preliminary findings

☐ Security Assessment Report (SAR)

- [ ] Review draft SAR from 3PAO
- [ ] Validate findings and risk ratings
- [ ] Provide additional evidence if needed
- [ ] Accept final SAR
- [ ] Develop remediation plan for identified weaknesses

☐ Remediation

- [ ] Address all high-risk findings before authorization

- [ ] Develop POA&M for moderate and low-risk items
- [ ] Implement corrective actions
- [ ] Provide evidence of remediation to 3PAO
- [ ] Obtain 3PAO validation of fixes

Phase 5: Authorization Process (Months 8-10)

☐ Package Preparation

- [ ] Compile complete authorization package
- [ ] Include SSP, SAP, SAR, and POA&M
- [ ] Add all supporting documentation
- [ ] Ensure all documents use FedRAMP templates
- [ ] Obtain executive signatures on required documents
- [ ] Prepare executive summary and briefing materials

☐ Agency Authorization (If pursuing Agency path)

- [ ] Identify agency sponsor
- [ ] Submit authorization package to agency
- [ ] Support agency review process
- [ ] Address agency questions and concerns
- [ ] Obtain Authority to Operate (ATO) from agency
- [ ] Submit to FedRAMP PMO for marketplace listing

☐ JAB Authorization (If pursuing JAB path)

- [ ] Submit package to FedRAMP PMO
- [ ] Participate in JAB kick-off meeting
- [ ] Support JAB technical review
- [ ] Address JAB questions and findings

- [ ] Participate in final authorization briefing
- [ ] Obtain JAB Provisional Authority to Operate (P-ATO)

Phase 6: Continuous Monitoring (Ongoing)

☐ Monthly Requirements

- [ ] Conduct vulnerability scanning
- [ ] Review and analyze scan results
- [ ] Update POA&M with new findings
- [ ] Submit monthly continuous monitoring deliverables
- [ ] Review security alerts and incidents
- [ ] Update risk assessment if needed

☐ Quarterly Requirements

- [ ] Review and update POA&M status
- [ ] Assess progress on remediation activities
- [ ] Conduct security control spot checks
- [ ] Review access control lists
- [ ] Update system inventory
- [ ] Submit quarterly continuous monitoring reports

☐ Annual Requirements

- [ ] Conduct annual security assessment
- [ ] Engage 3PAO for annual assessment
- [ ] Update System Security Plan
- [ ] Perform contingency plan testing
- [ ] Conduct penetration testing
- [ ] Review and update all policies and procedures

- [ ] Submit annual assessment report
- [ ] Obtain ATO renewal from authorizing official

☐ Significant Change Management

- [ ] Assess impact of system changes on security posture
- [ ] Update SSP for significant changes
- [ ] Conduct security impact analysis
- [ ] Obtain approval before implementing changes
- [ ] Update authorization package as needed
- [ ] Notify FedRAMP PMO of significant changes

Common FedRAMP Challenges and Solutions

Challenge 1: Documentation Burden

Solution: Start documentation early, use templates, assign dedicated technical writers, leverage automation tools for evidence collection.

Challenge 2: Cost Management

Solution: Budget for 3-year lifecycle, negotiate fixed-price 3PAO contracts, leverage existing security investments, consider FedRAMP Tailored for Low-Impact SaaS.

Challenge 3: Timeline Delays

Solution: Engage experienced FedRAMP consultants, maintain regular communication with 3PAO and agency, address findings promptly, allocate sufficient resources.

Challenge 4: Continuous Monitoring

Solution: Implement automated monitoring tools, establish dedicated compliance team, integrate security into DevOps processes, use FedRAMP-authorized tools.

Challenge 5: Finding Agency Sponsor

Solution: Leverage existing customer relationships, demonstrate clear value proposition, engage FedRAMP PMO for introductions, consider JAB path if no sponsor available.

FedRAMP Success Metrics

Track these key performance indicators throughout your FedRAMP journey:

- **Time to Authorization:** Target 6-12 months for Moderate impact
- **First-Time Pass Rate:** Aim for 90%+ control implementation success
- **POA&M Closure Rate:** Close 80%+ of findings within 30 days
- **Continuous Monitoring Compliance:** 100% on-time submission of monthly deliverables
- **Customer Adoption:** Number of agencies leveraging your FedRAMP authorization
- **Cost per Authorization:** Track against industry benchmarks

---

Essential Resources

FedRAMP Official Resources

- FedRAMP.gov - Official program website
- FedRAMP Marketplace - List of authorized cloud services
- FedRAMP Document Repository - Templates and guidance
- FedRAMP Training - Free online courses

NIST Publications

- NIST SP 800-53 Rev 5 - Security and Privacy Controls
- NIST SP 800-37 Rev 2 - Risk Management Framework

- NIST SP 800-171 - Protecting CUI in Nonfederal Systems

Industry Support

- FedRAMP PMO Help Desk - info@fedramp.gov
- 3PAO Marketplace - List of accredited assessors
- Cloud Service Provider Forum - Peer support community

How NexDyne Can Help

NexDyne Technology specializes in guiding organizations through the complete FedRAMP authorization process. Our services include:

FedRAMP Readiness Assessment

Comprehensive gap analysis against FedRAMP requirements with detailed remediation roadmap and cost estimates.

Documentation Development

Expert assistance creating System Security Plans, policies, procedures, and all required FedRAMP documentation.

Technical Implementation

Hands-on support implementing security controls, configuring monitoring tools, and establishing continuous monitoring programs.

3PAO Coordination

Management of third-party assessment process, evidence collection, and finding remediation.

Continuous Monitoring

Ongoing support maintaining FedRAMP compliance, submitting monthly deliverables, and managing annual assessments.

Our Track Record:

- 25+ successful FedRAMP authorizations
- 95% first-time assessment pass rate
- Average time to ATO: 8 months (vs. 12-month industry average)
- $2.3 billion in contract value enabled for clients

Next Steps

Ready to begin your FedRAMP journey? Contact NexDyne Technology for a complimentary readiness assessment:

Schedule Your Assessment:
Visit: www.nexdyne.com/contact
Email: federal@nexdyne.com
Phone: (202) 555-0100

Download Additional Resources:

- CMMC Implementation Guide
- Cloud Migration Playbook for Federal Agencies
- Federal Compliance Quick Reference Guide

This guide is provided for informational purposes and reflects FedRAMP requirements as of 2024. Requirements may change. Always consult official FedRAMP documentation and guidance for the most current information.

© 2024 NexDyne Technology. All rights reserved.